

**BỘ KHOA HỌC VÀ CÔNG NGHỆ
HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG
CƠ SỞ THÀNH PHỐ HỒ CHÍ MINH
KHOA CÔNG NGHỆ THÔNG TIN II**



BÁO CÁO ĐỒ ÁN MÔN HỌC

**ĐỀ TÀI: KHẢO SÁT VÀ ĐỀ XUẤT TRIỂN KHAI ĐẢM BẢO
AN TOÀN THÔNG TIN CHO CÔNG TY AM
ENTERTAINMENT
(GIAI ĐOẠN 2026 – 2031)**

Môn học : QUẢN LÝ AN TOÀN THÔNG TIN

Giảng viên hướng dẫn : Th.S Nguyễn Hữu Nguyên

Sinh viên thực hiện : Trần Thị Ánh Nguyệt

Mã số sinh viên : N22DCAT040

Lớp : D22CQAT01-N

Khóa : 2022 – 2027

Ngành : An toàn thông tin

Hệ : Đại học chính quy

TP.HCM, tháng 05 /2026

MỤC LỤC

DANH MỤC CÁC THUẬT NGỮ TIẾNG ANH VÀ VIẾT TẮT	2
CHƯƠNG I. KHẢO SÁT THỰC TRẠNG CÔNG TY	3
1.1. Lĩnh vực kinh doanh:	3
1.2. Thị trường hoạt động:	3
1.3. Quy mô công ty:.....	3
1.4. Mô hình tổ chức công nghệ thông tin và an toàn thông tin:	3
1.5. Hệ thống công nghệ thông tin hiện có:	4
1.6. Định hướng phát triển trong 5 năm tới:	4
CHƯƠNG II. PHƯƠNG ÁN THỰC HIỆN KẾ HOẠCH	5
2.1. Sơ lược:	5
2.2. Chi tiết các bước đảm bảo an toàn thông tin cho công ty AM Entertainment:..	5
2.3. Tổng kết:	13
TÀI LIỆU THAM KHẢO.....	14

DANH MỤC CÁC THUẬT NGỮ TIẾNG ANH VÀ VIẾT TẮT

Từ viết tắt	Thuật ngữ	Giải thích
ATTT	Information Security (InfoSec)	An toàn thông tin
ISMS	Information Security Management System	Hệ thống quản lý an toàn thông tin
ISO/IEC 27001	International Standard for Information Security Management	Tiêu chuẩn quốc tế về hệ thống quản lý ATTT
NIST	National Institute of Standards and Technology	Viện Tiêu chuẩn và Công nghệ Quốc gia Hoa Kỳ
SIEM	Security Information and Event Management	Hệ thống quản lý thông tin và sự kiện bảo mật (Sử dụng trong quản trị vận hành)
IDS	Intrusion Detection System	Hệ thống phát hiện xâm nhập
IPS	Intrusion Prevention System	Hệ thống ngăn chặn xâm nhập
EDR	Endpoint Detection and Response	Giải pháp phát hiện và phản hồi điểm cuối
RBAC	Role-Based Access Control	Kiểm soát truy cập dựa trên vai trò
MFA	Multi-Factor Authentication	Xác thực đa yếu tố
SETA	Security Education, Training and Awareness	Chương trình giáo dục, đào tạo và nâng cao nhận thức bảo mật
EISP	Enterprise Information Security Policy	Chính sách an toàn thông tin doanh nghiệp
ISSP	Issue-Specific Security Policy	Chính sách an toàn cho vấn đề cụ thể
SysSP	System-Specific Security Policy	Chính sách an toàn cho hệ thống cụ thể
CIA	Confidentiality – Integrity – Availability	Bộ ba bảo mật: Tính Bí mật – Toàn vẹn – Sẵn sàng
CISO	Chief Information Security Officer	Giám đốc An toàn thông tin
CSIRT	Computer Security Incident Response Team	Nhóm phản ứng nhanh sự cố an ninh máy tính
SDLC	System Development Life Cycle	Vòng đời phát triển hệ thống
SecSDLC	Security System Development Life Cycle	Vòng đời phát triển hệ thống bảo mật

CHƯƠNG I. KHẢO SÁT THỰC TRẠNG CÔNG TY

1.1. Lĩnh vực kinh doanh:

Công ty AM Entertainment hoạt động trong lĩnh vực giải trí và truyền thông số, chuyên quản lý, đào tạo và phát triển hình ảnh nghệ sĩ độc quyền. Ngoài ra, công ty còn tổ chức các sự kiện âm nhạc, biểu diễn nghệ thuật, sản xuất nội dung truyền thông và khai thác bản quyền các sản phẩm âm nhạc trên môi trường số.

Bên cạnh hoạt động quản lý nghệ sĩ, công ty còn tham gia phát triển các chiến dịch quảng bá thương hiệu, hợp tác với KOLs và xây dựng nội dung số trên các nền tảng trực tuyến nhằm mở rộng độ phủ thương hiệu và tăng doanh thu truyền thông.

1.2. Thị trường hoạt động:

Hiện nay, AM Entertainment hoạt động mạnh tại thị trường Việt Nam và đang mở rộng hợp tác sản xuất nội dung số với cá đối tác tại Thái Lan và Hàn Quốc.

Nguồn doanh thu của công ty đến từ:

- Hoạt động tổ chức sự kiện và biểu diễn nghệ thuật.
- Quản lý nghệ sĩ và quảng cáo thương hiệu.
- Khai thác doanh thu trên các nền tảng số xuyên biên giới như: YouTube, Spotify, TikTok.

1.3. Quy mô công ty:

Hiện tại, công ty có khoảng 60 nhân viên chính thức và quản lý trực tiếp khoảng 20 nghệ sĩ, KOLs độc quyền.

Cơ cấu tổ chức của công ty bao gồm các bộ phận: Pháp lý và Bản quyền, truyền thông & Marketing, quản lý nghệ sĩ, hậu kỳ sản xuất nội dung, hỗ trợ kỹ thuật và vận hành hệ thống.

Ngoài ra, công ty đang quản lý hơn 100 tài khoản mạng xã hội có xác thực (tick xanh) của nghệ sĩ và doanh nghiệp trên nhiều nền tảng khác nhau.

1.4. Mô hình tổ chức công nghệ thông tin và an toàn thông tin:

Hiện tại, công ty chỉ có 01 nhân viên phụ trách kỹ thuật (IT Support), chịu trách nhiệm hỗ trợ hệ thống công nghệ thông tin và đồng thời kiêm nhiệm vụ quản lý các tài khoản mạng xã hội của nghệ sĩ. Công ty chưa có: Bộ phận công nghệ thông tin riêng biệt, nhân sự chuyên trách về an toàn thông tin, quy trình ứng cứu sự cố bảo mật chuyên nghiệp, hệ thống giám sát và quản lý an toàn thông tin tập trung.

Mô hình tổ chức hiện tại còn đơn giản, chưa đáp ứng đầy đủ yêu cầu bảo mật đối với doanh nghiệp hoạt động mạnh trên môi trường số và quản lý nhiều tài sản thông tin có giá trị cao.

1.5. Hệ thống công nghệ thông tin hiện có:

Hệ thống lưu trữ dữ liệu NAS đặt tại văn phòng để lưu trữ: Bản thu âm gốc chưa phát hành, video và hình ảnh nghệ sĩ, hợp đồng bảo mật, dữ liệu truyền thông nội bộ

Hệ thống website giới thiệu nghệ sĩ, lịch trình biểu diễn và các hoạt động truyền thông được triển khai trên nền tảng Cloud

Hệ thống quản lý hơn 100 tài khoản mạng xã hội của nghệ sĩ và công ty trên: Facebook, Instagram, TikTok.

Hệ thống mạng nội bộ văn phòng gồm khoảng 50 máy tính làm việc cùng hệ thống Wifi dành cho nhân viên và khách.

1.6. Định hướng phát triển trong 5 năm tới:

Trong giai đoạn 2026 – 2031, AM Entertainment định hướng mở rộng quy mô hoạt động và đẩy mạnh chuyển đổi số với các mục tiêu chính như sau:

Phát triển ứng dụng di động riêng (Fandom App) nhằm kết nối cộng đồng người hâm mộ với nghệ sĩ.

Tích hợp hệ thống bán vé sự kiện và kinh doanh vật phẩm lưu niệm thông qua thanh toán hiện tử và ví điện tử.

Số hóa toàn bộ quy trình quản lý hợp đồng và khai thác bản quyền âm nhạc bằng công nghệ Blockchain.

Tăng cường bảo vệ dữ liệu cá nhân của nghệ sĩ và các sản phẩm sáng tạo trước khi phát hành nhằm hạn chế tình trạng rò rỉ dữ liệu.

Thành lập tổ phản ứng nhanh về an toàn thông tin để xử lý các sự cố như: Chiếm quyền điều khiển tài khoản mạng xã hội, tấn công truyền thông, giả mạo thương hiệu nghệ sĩ, phát tán nội dung trái phép

Mở rộng quy mô nhân sự lên khoảng 150 người và tuyển dụng tối thiểu 03 chuyên gia bảo mật nhằm xây dựng bộ phận an toàn thông tin chuyên trách trong tương lai.

CHƯƠNG II. PHƯƠNG ÁN THỰC HIỆN KẾ HOẠCH

2.1. Sơ lược:

❖ **Giai đoạn 1: Khảo sát, nhận dạng và đánh giá rủi ro (3 tháng):**

- Kiểm kê tài sản CNTT, dữ liệu và tài khoản mạng xã hội.
- Phân loại dữ liệu theo mức độ nhạy cảm.
- Đánh giá rủi ro, xác định mối đe dọa và lỗ hổng hệ thống.
- Xây dựng chính sách ATTT cơ bản và thiết lập baseline bảo mật.

Kết quả: Báo cáo hiện trạng ATTT, danh mục tài sản quan trọng và bảng phân tích rủi ro.

❖ **Giai đoạn 2: Thiết kế và Lập kế hoạch quản trị (Năm 1): Xây dựng khung pháp lý nội bộ và chuẩn bị nguồn lực con người:**

Ban hành chính sách bảo mật và quy trình truy cập theo nguyên tắc “Need-to-know”.

Tuyển dụng CISO và tách nhiệm vụ với IT Support.

Xây dựng kế hoạch ứng cứu sự cố (IRP) và khôi phục thảm họa (DRP).

Kết quả: Bộ chính sách ATTT và bản thiết kế kiến trúc bảo mật tổng thể.

❖ **Giai đoạn 3: Triển khai kỹ thuật và vận hành (Năm 2 – 3): Đưa các kế hoạch vào thực tế và tích hợp bảo mật cho các sản phẩm số mới:**

Triển khai MFA, tường lửa và IDS để giám sát hệ thống.

Tích hợp bảo mật vào quá trình phát triển ứng dụng (SecSDLC).

Đào tạo SETA định kỳ cho nhân viên và nghệ sĩ.

Thành lập CSIRT và diễn tập xử lý sự cố thực tế.

Kết quả: Hệ thống bảo mật hoạt động ổn định, 100% nhân viên hoàn thành đào tạo.

❖ **Giai đoạn 4: Duy trì, tối ưu hóa và tuân thủ (Năm 4 – 5): Hoàn thiện đội ngũ và đặt các tiêu chuẩn quốc tế khi mở rộng quy mô:**

Ứng dụng Blockchain trong quản lý bản quyền.

Đánh giá hiệu quả kiểm soát bảo mật và cải tiến liên tục.

Đảm bảo tuân thủ Luật An ninh mạng và hướng tới ISO/IEC 27001.

Hoàn thiện đội ngũ bảo mật chuyên trách.

Kết quả: Hệ thống ATTT đạt mức trưởng thành cao, đáp ứng tiêu chuẩn quốc tế và hỗ trợ mở rộng kinh doanh.

2.2. Chi tiết các bước đảm bảo an toàn thông tin cho công ty AM Entertainment:

2.2.1. Tầm quan trọng của quản lý, lãnh đạo trong ATTT:

Ban lãnh đạo đóng vai trò quan trọng trong việc xây dựng chiến lược ATTT, phê duyệt chính sách EISP và đảm bảo hoạt động bảo mật phù hợp với định hướng phát triển của AM Entertainment.

Trong lộ trình 5 năm, công ty cần đầu tư hạ tầng bảo mật như MFA, IDS/IPS và Cloud an toàn, đồng thời tuyển dụng đội ngũ ATTT chuyên trách nhằm giảm tải cho IT Support.

Bên cạnh đó, lãnh đạo cần thúc đẩy chương trình SETA nhằm nâng cao nhận thức bảo mật cho nhân viên và nghệ sĩ, đặc biệt trong quản lý tài khoản mạng xã hội và bảo vệ dữ liệu sáng tạo

Việc quản trị ATTT hiệu quả sẽ giúp AM Entertainment bảo vệ uy tín thương hiệu và tạo nền tảng an toàn khi mở rộng hoạt động sang thị trường Thái Lan và Hàn Quốc.

2.2.2. Tuân thủ pháp luật và tiêu chuẩn bảo mật:

Để giảm thiểu trách nhiệm pháp lý và mở rộng thị trường quốc tế, công ty thực hiện lộ trình tuân thủ nghiêm ngặt các quy định sau:

- Pháp luật Việt Nam: Tuân thủ Luật An ninh mạng 2025 (có hiệu lực từ 01/07/2026) về bảo vệ hạ tầng dữ liệu. Thực thi nghiêm túc việc bảo vệ thông tin cá nhân (PII) theo Luật ATTT mạng 2015 và xây dựng chuẩn mực đạo đức nghệ sĩ trên không gian mạng theo Quyết định 874/QĐ-BTTTT.

- Tiêu chuẩn ISO/IEC 27001: Đặt mục tiêu đạt chứng nhận trong 5 năm tới để chuẩn hóa Hệ thống quản lý an toàn thông tin (ISMS). Việc này giúp quản trị rủi ro tập trung cho dữ liệu NAS/Cloud và minh chứng năng lực bảo mật với các đối tác Thái Lan, Hàn Quốc.

Quy định quốc tế và ngành:

- GDPR: Bảo vệ quyền riêng tư và "quyền được quên" của người hâm mộ tại thị trường EU.

- PCI DSS: Áp dụng các biện pháp kiểm soát truy cập và mã hóa dữ liệu thẻ thanh toán trên App Fandom.

- Bản quyền số: Tuân thủ các luật như DMCA để bảo vệ tài sản trí tuệ và hình ảnh nghệ sĩ trên các nền tảng toàn cầu.

Chuẩn mực nghề nghiệp: Duy trì tiêu chuẩn Trách nhiệm thích đáng (Due Care) và Thâm định thích đáng (Due Diligence) để chứng minh sự nỗ lực không ngừng trong việc bảo vệ tài sản thông tin và tránh các cáo buộc cầu thả pháp lý.

Việc tuân thủ đồng bộ các khung pháp lý này là yếu tố then chốt giúp AM Entertainment tập trung vào mục tiêu kinh doanh chiến lược một cách an toàn

2.2.3. Chính sách an toàn thông tin:

Trong kế hoạch chiến lược 5 năm, hệ thống chính sách được xây dựng theo ba cấp độ dựa trên mô hình quản trị chuẩn hóa:

❖ Chính sách ATTT doanh nghiệp (EISP):

Đây là chính sách cấp cao nhất, thể hiện cam kết của Ban giám đốc trong việc bảo vệ tính bí mật, toàn vẹn và khả dụng của dữ liệu công ty.

Chính sách quy định ATTT là trách nhiệm chung của nhân viên, nghệ sĩ và đối tác, đồng thời yêu cầu tuân thủ Luật An ninh mạng 2025 và tiêu chuẩn ISO/IEC 27001.

❖ Chính sách cho các vấn đề cụ thể (ISSP):

ISSP đưa ra hướng dẫn chi tiết cho từng hoạt động nhằm giảm thiểu rủi ro trong vận hành hàng ngày.

Công ty áp dụng MFA cho tài khoản mạng xã hội, quy định chống rò rỉ dữ liệu trên NAS, bảo mật thiết bị cá nhân (BYOD) và kiểm soát truy cập theo vai trò (RBAC) dựa trên nguyên tắc “Need-to-know”.

Mỗi bộ phận chỉ được cấp quyền truy cập phù hợp với nhiệm vụ nhằm hạn chế rủi ro lộ lọt dữ liệu.

Chi tiết phân quyền được thể hiện Bảng 1:

Vai trò	Hệ thống lưu trữ NAS	Quản lý mạng xã hội	App Fandom & ví điện tử	Dữ liệu cá nhân nghệ sĩ	Mức độ truy cập
Nghệ sĩ	Xem/ tải sản phẩm cá nhân	Truy cập tài khoản riêng	Xem báo cáo fandom	Xem dữ liệu cá nhân	Giới hạn theo tài sản sở hữu
Nhân viên hậu kỳ	Toàn quyền xử lý	x	x	x	Truy cập dữ liệu sáng tạo
Marketing/ PR	Xem (bản demo)	Đăng bài, phản hồi	Giám sát nội dung	x	Quản lý hình ảnh công chúng

Pháp lý/ Bản quyền	Xem hợp đồng	x	x	Xem thông tin hồ sơ	Kiểm soát tính pháp lý
IT Support	Vận hành, backup	Hỗ trợ kỹ thuật	Vận hành hạ tầng	Quản trị tài khoản	Không truy cập nội dung dữ liệu
Chuyên gia bảo mật	Giám sát, audit	Giám sát an toàn	Quản trị bảo mật	Giám sát truy cập	Toàn quyền kiểm soát an ninh
Ban giám đốc	Xem báo cáo	x	Xem doanh thu	Xem thông tin nhạy cảm	Quyền đọc báo cáo chiến lược

Ghi chú: x là không được phép truy cập.

❖ *Chính sách cho các hệ thống cụ thể (SysSP):*

SysSP quy định cấu hình kỹ thuật và cách vận hành cho từng hệ thống công nghệ.

Hệ thống NAS được áp dụng ACL và mã hóa dữ liệu, Cloud/App triển khai tường lửa, IDS/IPS và giám sát log, còn Blockchain sử dụng các giao thức bảo mật riêng cho hợp đồng thông minh và bản quyền số.

❖ *Áp dụng và duy trì chính sách:*

Nhân viên và nghệ sĩ phải đọc, ký cam kết tuân thủ và tham gia đào tạo SETA.

Chính sách được rà soát định kỳ nhằm phù hợp với công nghệ và các mối đe dọa mới.

2.2.4. Chương trình đào tạo và nâng cao nhận thức (SETA):

Chương trình SETA giúp giảm rủi ro con người gây ra và xây dựng văn hóa bảo mật trong doanh nghiệp:

❖ *Ba thành phần cốt lõi của SETA:*

- Awareness (Nhận thức): Nhận biết phishing và lừa đảo
- Training (Đào tạo): Đào tạo kỹ năng xử lý và bảo mật hệ thống.
- Education (Giáo dục): Trang bị kiến thức quản trị ATTT cho lãnh đạo và chuyên gia.

❖ *Chiến lược triển khai 7 bước tại AM Entertainment:*

- Bước 1: Xác định mục tiêu bảo vệ dữ liệu sáng tạo và tài khoản nghệ sĩ.
- Bước 2: Phân công nhân sự đào tạo hoặc thuê chuyên gia
- Bước 3: Phân loại đối tượng đào tạo theo từng nhóm nhân sự

- Bước 4: Tạo động lực bằng cách nhấn mạnh lợi ích bảo vệ thương hiệu cá nhân
- Bước 5: Quản lý và theo dõi hoạt động đào tạo
- Bước 6: Cập nhật nội dung theo các hình thức tấn công mới.
- Bước 7: Đánh giá hiệu quả qua các chỉ số như tỷ lệ nhận diện email giả mạo hay số sự cố giảm xuống.

❖ *Gắn kết SETA với quản lý nhân sự:*

SETA được tích hợp vào quy trình nhân sự:

- Nhân viên và nghệ sĩ mới phải ký cam kết tuân thủ ATTT.
- Kết quả tham gia đào tạo và mức độ tuân thủ được đưa vào đánh giá hiệu suất hàng năm.

2.2.5. Nhận dạng và đánh giá rủi ro an toàn thông tin:

❖ *Nhận dạng và ưu tiên tài sản thông tin:*

- Con người: Gồm 60 nhân viên, 20 nghệ sĩ/ KOLs và nhân sự IT Support hiện tại.
- Dữ liệu: Các tài nguyên nhạy cảm nhất gồm bản thu âm gốc, hình ảnh chưa được công bố trên NAS, hợp đồng bảo mật và thông tin cá nhân của nghệ sĩ.
- Phần cứng và mạng: Hệ thống NAS tại văn phòng, 50 máy tính làm việc, hạ tầng Cloud và mạng Wifi khách.
- Tài sản vô hình: Hơn 100 tài khoản mạng xã hội có tick xanh – đây là tài sản cốt lõi tạo nên hình ảnh và doanh thu.

❖ *Đánh giá nguy cơ (Threat Assessment):*

Nguy cơ	Mô tả
Tổng tiền thông tin	Đe dọa phát tán sản phẩm sáng tạo bị “leak” từ NAS để đòi tiền chuộc
Xâm nhập và gián điệp	Các nỗ lực tấn công chiếm quyền điều khiển 100 tài khoản mạng xã hội của nghệ sĩ.

Lỗi hoặc sai sót do con người	Do hiện tại chỉ có 01 nhân sự IT kiêm nhiệm quá nhiều việc, dẫn đến cấu hình sai hệ thống hoặc sơ suất trong quá trình quản lý mật khẩu.
Tấn công phần mềm	Mã độc, lừa đảo (phishing) nhắm vào nghệ sĩ để lấy thông tin đăng nhập
Insider Threat	Nhân viên nội bộ làm rò rỉ dữ liệu

❖ *Đánh giá tính dễ bị tổn thương (Vulnerability Assessment):*

Tài sản	Điểm yếu
Tài khoản mạng xã hội	Chưa bật MFA đầy đủ
NAS nội bộ	Chưa mã hóa dữ liệu
Website Cloud	Chưa có WAF
Máy trạm	Chưa cập nhật bản vá đầy đủ
Wifi nội bộ	Chưa phân tách VLAN
Quy trình quản lý	Chưa có chính sách an toàn thông tin

❖ *Phân tích và xác định mức độ rủi ro:*

Tài sản	Điểm yếu	Khả năng	Tác động	Hạng rủi ro
Tài sản Facebook nghệ sĩ	Không bật MFA	5	5	25
NAS lưu trữ bản thu âm	Không mã hóa dữ liệu	4	5	20
Website Cloud	Chưa có WAF	3	4	12
Máy trạm nội bộ	Chưa cập nhật bản vá	4	4	16
Hợp đồng nghệ sĩ	Phân quyền truy cập yếu	3	5	15

Wifi nội bộ	Chưa phân tách mạng	3	3	9
-------------	---------------------	---	---	---

❖ *Xử lý rủi ro:*

Phòng thủ: Triển khai SIEM, MFA, RBAC và IAM

Chuyển giao: Sử dụng bảo hiểm an ninh mạng và Cloud đạt chuẩn ISO

Giảm thiểu: Xây dựng IRP và DRP

Chấp nhận: Chấp nhận rủi ro ở mức cho phép

Chấm dứt: Loại bỏ các công nghệ hoặc ứng dụng có rủi ro cao.

2.2.6. Mô hình bảo mật áp dụng (ISO/IEC 27001, NIST):

❖ *Tiêu chuẩn ISO/ IEC 27001:*

Chuẩn hóa quản trị: Thiết lập các chính sách và biện pháp kiểm soát bảo mật đồng bộ cho tất cả các bộ phận từ Pháp lý, Marketing đến Hậu kỳ.

Bảo vệ tài sản nhạy cảm: Đảm bảo tính sẵn sàng và khả năng phục hồi cho các hệ thống cốt lõi như kho dữ liệu NAS chứa sản phẩm gốc và hệ thống Cloud.

Chứng minh năng lực với đối tác: Đạt được chứng nhận ISO 27001 là minh chứng rõ ràng nhất về trách nhiệm thích đáng của công ty trong việc bảo vệ bản quyền nghệ sĩ khi làm việc với các đối tác Hàn Quốc và Thái Lan.

Lộ trình thực hiện: Công ty đặt mục tiêu đạt chứng nhận vào cuối năm thứ 5 thông qua quy trình 3 bước: đánh giá ban đầu, xây dựng sổ tay hướng dẫn tuân thủ và kiểm định cấp chứng chỉ.

❖ *Khung hướng dẫn NIST (National Institute of Standards and Technology):*

NIST cung cấp 5 chức năng cốt lõi giúp bảo vệ hình ảnh nghệ sĩ và sản phẩm sáng tạo:

Identify: Nhận dạng tài sản và rủi ro

Protect: Bảo vệ dữ liệu bằng MFA và đào tạo SETA

Detect: Phát hiện xâm nhập bằng IDS/IPS

Respond: Ứng phó sự cố thông qua CSIRT

Recover: Khôi phục dữ liệu và hệ thống sau sự cố.

2.2.7. Quản lý nhân sự gắn với bảo mật:

Công ty quản lý ATTT xuyên suốt vòng đời nhân sự từ tuyển dụng đến nghỉ việc.

Nhân viên và nghệ sĩ phải ký NDA, tham gia đào tạo bảo mật và tuân thủ chính sách ATTT.

Trong quá trình làm việc, công ty áp dụng nguyên tắc tách biệt nhiệm vụ và đánh giá tuân thủ bảo mật trong KPI hàng năm.

Khi nhân sự nghỉ việc, toàn bộ quyền truy cập sẽ được thu hồi ngay lập tức nhằm hạn chế rủi ro rò rỉ dữ liệu.

Mục tiêu tổng thể : Giảm nguy cơ tai nạn thông tin, xây dựng văn hóa chuyên nghiệp, nâng cao ý thức bảo vệ giá trị sáng tạo.

2.2.8. Kế hoạch ứng phó sự cố và phục hồi thảm họa:

❖ Kế hoạch ứng phó sự cố (IRP):

Thành lập Nhóm ứng cứu sự cố (CSIRT): Bao gồm nhân sự bảo mật chuyên trách, IT Support và đại diện bộ phận Pháp lý. CSIRT có thẩm quyền ngắt kết nối thiết bị hoặc giám sát các hoạt động đáng ngờ khi cần thiết.

Quy trình xử lý sự cố theo NIST: Thực hiện qua 3 giai đoạn cơ bản:

Detection: Nhận diện các dấu hiệu sự cố (ví dụ: nghệ sĩ không đăng nhập được tài khoản, tệp lạ xuất hiện trên NAS) qua hệ thống giám sát IDPS.

Response: Ngay lập tức thực hiện các quy trình hoạt động chuẩn (SOP) để ngăn chặn sự cố lây lan, cách ly hệ thống bị ảnh hưởng và thông báo cho nhân sự chủ chốt.

Recovery: Khôi phục dữ liệu và hệ thống.

Diễn tập (Wargame): Tổ chức diễn tập định kỳ (ví dụ: giả lập tình huống mất quyền quản trị tài khoản Facebook nghệ sĩ) để kiểm tra quy trình và nâng cao khả năng phản ứng của đội ngũ.

❖ Kế hoạch phục hồi thảm họa (DRP) và Duy trì kinh doanh (BCP):

Phân tích tác động kinh doanh (BIA): Xác định thứ tự ưu tiên khôi phục cho các quy trình then chốt (NAS, App Fandom).

Thiết lập chỉ số phục hồi mục tiêu:

- Hệ thống NAS: RTO = 8h, RPO = 4h (sao lưu gần nhất).
- App Fandom & Ví điện tử: RTO = 2h, RPO = 15 phút để đảm bảo giao dịch liên tục.

Chiến lược dự phòng: Triển khai sao lưu dữ liệu NAS đa vùng (Multi-region/Cloud) và chuẩn bị địa điểm thay thế (Alternate site) để duy trì hoạt động truyền thông nghệ sĩ khi trụ sở chính gặp sự cố vật lý.

Việc sở hữu bộ kế hoạch CP hoàn chỉnh giúp AM Entertainment bảo vệ tối đa giá trị thương hiệu và duy trì niềm tin bền vững với nghệ sĩ và người hâm mộ

2.2.9. Duy trì bảo mật và quản lý thay đổi:

Công ty thực hiện đánh giá bảo mật định kỳ, kiểm toán hệ thống và quản lý thay đổi cho NAS, Cloud và ứng dụng.

Hệ thống SIEM, quản lý bản vá và giám sát liên tục giúp phát hiện sớm rủi ro và duy trì khả năng đáp ứng tiêu chuẩn ISO/IEC 27001.

Tóm lại, đây là một chu trình liên tục gồm đánh giá – kiểm toán – quản lý thay đổi – giám sát – đánh giá lại rủi ro, giúp hệ thống luôn sẵn sàng và đáp ứng chuẩn quốc tế.

2.3. Tổng kết:

Kế hoạch ATTT giai đoạn 2026–2031 giúp AM Entertainment xây dựng hệ thống bảo mật bền vững, gắn ATTT với hoạt động kinh doanh và bảo vệ tài sản số như App Fandom, dữ liệu NAS và bản quyền Blockchain.

Công ty hướng đến mô hình quản trị rủi ro chủ động thông qua phân tích TVA, đồng thời nâng cao nhận thức bảo mật cho nhân viên và nghệ sĩ bằng chương trình SETA.

Ngoài ra, doanh nghiệp thực hiện các nguyên tắc Due Care và Due Diligence nhằm giảm rủi ro pháp lý, nâng cao uy tín và đáp ứng tiêu chuẩn quốc tế.

❖ Kiến nghị đối với Ban lãnh đạo:

Phê duyệt ngân sách cho hạ tầng bảo mật và đào tạo nhân sự.

Ban hành và thực thi các chính sách EISP, ISSP và SysSP.

Tuyển dụng nhân sự ATTT chuyên trách.

Thường xuyên rà soát rủi ro và diễn tập IRP/DRP.

Việc triển khai đồng bộ các giải pháp trên sẽ giúp AM Entertainment xây dựng hệ thống ATTT vững chắc và hỗ trợ mục tiêu mở rộng quốc tế trong tương lai.

TÀI LIỆU THAM KHẢO

1. M. E. Whitman và H. J. Mattord, *Principles of Information Security*, 7th ed. Boston, MA: Cengage Learning, 2021.
2. *An toàn thông tin, An toàn không gian mạng và bảo vệ quyền riêng tư – Hệ thống quản lý an toàn thông tin – Các yêu cầu*, Tiêu chuẩn ISO/IEC 27001:2022.
3. *An toàn thông tin, An toàn không gian mạng và bảo vệ quyền riêng tư – Quản trị an toàn thông tin*, Tiêu chuẩn ISO/IEC 27014:2020.
4. *Information Security Handbook: A Guide for Managers*, NIST Special Publication 800-100, National Institute of Standards and Technology (NIST), 2007.
5. *Contingency Planning Guide for Federal Information Systems*, NIST Special Publication 800-34 Rev. 1, NIST, 2010.
6. *Guide for Conducting Risk Assessments*, NIST Special Publication 800-30 Rev. 1, NIST, 2012.
7. *Security and Privacy Controls for Information Systems and Organizations*, NIST Special Publication 800-53 Rev. 5, NIST, 2020.
8. *Guide for Applying the Risk Management Framework to Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy*, NIST Special Publication 800-37 Rev. 2, NIST, 2018.
9. *Security Considerations in the System Development Life Cycle*, NIST Special Publication 800-64 Rev. 2, NIST, 2008.
10. *Guide for Cybersecurity Event Recovery*, NIST Special Publication 800-184, NIST, 2016.
11. *Luật An toàn thông tin mạng*, Số 86/2015/QH13, Quốc hội Việt Nam, ban hành ngày 19 tháng 11 năm 2015.
12. *Luật An ninh mạng*, Số 24/2018/QH14, Quốc hội Việt Nam, ban hành ngày 12 tháng 06 năm 2018.
13. *Bộ bài giảng môn học Quản lý An toàn Thông tin*, ThS.Nguyễn Hữu Nguyên, Học viện Công nghệ Bưu chính Viễn thông cơ sở Tp.Hồ Chí Minh.
14. *Thông tư Quy định Chuẩn Kỹ năng nhân lực công nghệ thông tin chuyên nghiệp*, Thông tư 17/2021/TT-BTTTT, Bộ Thông tin và Truyền thông Việt Nam, 2021.